4.2.1 Analyzing AI Attacks

A brief overview of how cybersecurity teams must now defend both traditional enterprise environments and the AI systems within them. Using frameworks like **MITRE ATLAS** and the **NIST AI RMF** helps map real attacks to actionable controls across the AI lifecycle.

SECAI+ PREP

LESSON 4.2.1

Prompt Injection & Jailbreaking

How It Works

Attackers override system instructions via user input, documents, emails, or web pages causing models to reveal hidden config, ignore guardrails, or perform unintended actions.

Defenses

- Treat all external text as untrusted input
- Delimit and encode model inputs
- Constrain tool access strictly
- Require human approval for sensitive actions
- Log all tool invocations

Reference: OWASP LLM Top 10, OpenAI and Microsoft vendor guidance

Poisoning & Input Manipulation

Data & Model Poisoning

Corrupts training data so the model learns from a distorted perspective. Model poisoning goes further tampering directly with gradients and weights.

- Data lineage validation
- Reproducible pipelines
- Drift checks & canary records per training stage

Input Manipulation

Subtle changes to images or audio that are imperceptible to humans but highly impactful to models causing misclassification or unexpected behavior.

- Human-in-the-loop for high-risk workflows
- Human approval gates before any action is taken

Hallucinations & Bias

Hallucinations

Models generate false but believable output that downstream systems act on potentially causing **outages, data breaches, or corruption**.

- Separate generation from execution
- Cross-model validation
- Sanitize tool args, validate outputs (OWASP)

Bias

Misleading content incorporated into training, or prompts crafted to produce harmful stereotypes and skewed outputs.

- Curated datasets with clear sources
- Model cards for transparency
- Periodic audits & escalation paths

AI Assistants, Integrations & Chain of Thought

Poorly Controlled AI Assistants

Can be tricked into exfiltrating data or taking malicious actions on behalf of an attacker.

Controls: Least-privilege permissions, full audit trails of all actions.

Application Integration Manipulation

Attackers inject data, modify API calls, or tamper with integration points between systems.

Controls: Input validation, API authentication, anomaly monitoring.

Chain of Thought (CoT)

Step-by-step reasoning is a prime injection target and may leak API keys or sensitive data.

Controls: Protect integrity and confidentiality of CoT reasoning at all stages.

Detection: Poisoning & Input Manipulation

Detecting Poisoning

- Monitor **data drift** — changes in data distribution over time
- Calculate **similarity scores** against trusted baseline datasets
- Run **reproducibility checks** at each stage of training

Detecting Input Manipulation

- Automated **integrity checks** on images and media inputs
- **Statistical pattern alerts** for anomalous input distributions
- **Language and acoustic analysis** to flag unnatural elements

Detection: Schema Validation, Hallucinations & Bias

Schema Validation

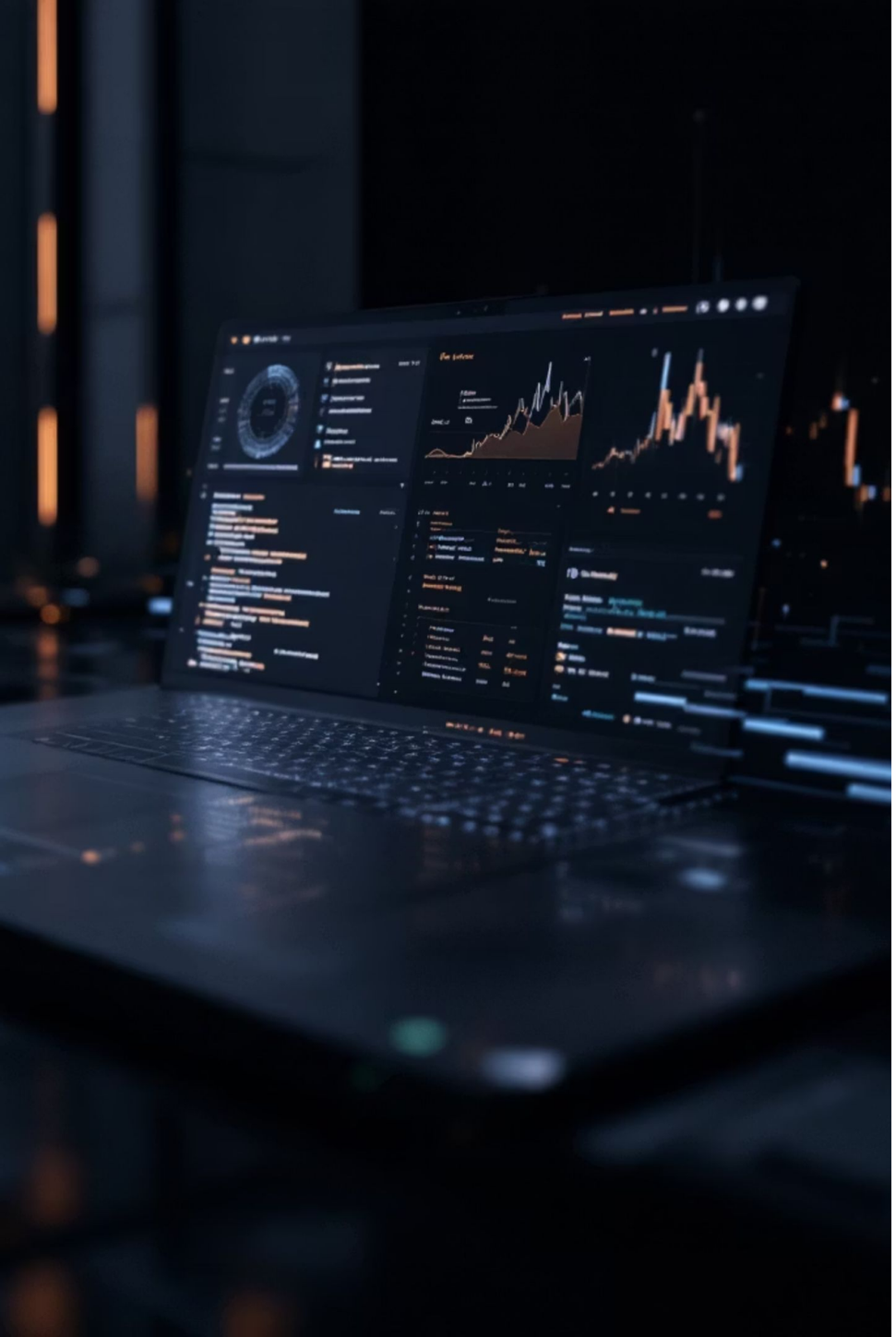
Pre-define expected output schema (e.g., JSON) and reject any output that doesn't match. Blocks most prompt injections and exfiltration silently. Validation failure spikes signal active attacks.

Hallucination Detection

Cross-model validation using independent answers from multiple models. Factual consistency checks against authoritative knowledge sources to catch fabricated outputs.

Bias Detection

Periodic audits using fairness benchmark datasets. Visualizations of data distributions to surface skewed patterns before they propagate into production.



Detection: AI Assistants & Integrations

AI Assistant Monitoring

Log **all automated actions** — files read, messages sent, commands executed. Apply behavioral analytics to detect unusual usage patterns that deviate from established baselines.

Integration Monitoring

Deploy **API monitoring combined with input validation** to verify that requests match expected formats. Use anomaly detection to flag irregular traffic volumes or unusual API request sequences that may indicate tampering.

Key Takeaways

Foundational Frameworks

MITRE ATLAS + NIST AI RMF provide the foundation for mapping AI attacks to actionable controls across the full lifecycle.

Layered Defenses for Injection

Prompt injection and jailbreaking require layered, predictable defenses not single filters. No one control is sufficient.

Poisoning Targets Data & Weights

Poisoning attacks corrupt data before training; model poisoning corrupts weights directly, both require pipeline integrity controls.

Schema Validation is High-Impact

Schema validation is a simple, high-impact defense against many prompt injection variants — validation failure spikes signal active attacks.

Universal Controls

Least privilege, audit trails, and anomaly monitoring apply across **all** AI attack categories from assistants to integrations to CoT reasoning.